

Enterprise Security & Compliance Program Design

Consulting Case Study — ComplianceForge

1. Executive Summary

This engagement demonstrates the design of an enterprise-grade cybersecurity governance, risk, and compliance (GRC) program for a fictional fintech organization, NovaBank Cloud Services.

The objective is to simulate how a real-world security consulting engagement would structure governance, implement controls, and establish continuous compliance monitoring in a cloud-native and AI-enabled environment.

2. Client Context

Industry: Fintech (Cloud-Native Banking Platform)

Environment: Multi-cloud, API-driven architecture, AI-enabled services

Key Challenges: - Lack of centralized governance - Fragmented risk visibility - No formal compliance mapping - Emerging AI security risks - Limited DevSecOps maturity

3. Consulting Objectives

- Establish security governance structure
 - Define enterprise risk management framework
 - Map controls to global compliance standards
 - Introduce DevSecOps security automation
 - Design AI security governance model
 - Improve audit readiness posture
-

4. Approach

Phase 1 — Governance Design

- Security program charter
- Executive oversight structure

- Policy lifecycle definition

Phase 2 — Risk Management

- Enterprise risk register creation
- Risk scoring methodology
- Mitigation strategy mapping

Phase 3 — Compliance Engineering

- ISO 27001 mapping
- NIST CSF alignment
- SOC 2 trust principles mapping
- CIS Controls integration

Phase 4 — Security Operations Design

- Incident response playbooks
- Threat modeling (STRIDE approach)
- Security monitoring strategy

Phase 5 — DevSecOps Integration

- CI/CD security pipeline design
- SAST, SCA, IaC scanning integration
- Automated compliance checks

Phase 6 — AI Security Governance

- Prompt injection risk modeling
 - LLM threat surface analysis
 - AI usage governance policies
-

5. Architecture Overview

The security architecture includes:

- Identity & Access Management (IAM)
 - Multi-Factor Authentication (MFA)
 - API Gateway Security Layer
 - Centralized Logging & SIEM
 - Cloud Security Posture Management (CSPM)
 - AI Security Control Layer
-

6. Key Deliverables

- Governance Charter
 - Risk Register
 - Compliance Mapping Matrix
 - Incident Response Playbooks
 - DevSecOps Security Pipeline
 - AI Security Threat Model
 - Security Architecture Design
-

7. Outcomes (Simulated)

- Structured enterprise-grade security program
 - Defined compliance alignment strategy
 - Improved risk visibility model
 - Introduced automation for security enforcement
 - Established AI security governance framework
-

8. Consulting Value Demonstrated

This project demonstrates the ability to:

- Design enterprise security programs
 - Translate compliance frameworks into operational controls
 - Build risk-based security models
 - Integrate DevSecOps into governance structures
 - Address emerging AI security risks
-

9. Conclusion

This case study represents a full lifecycle design of a modern cybersecurity governance program aligned with industry best practices and regulatory frameworks.